

Zadanie 08: Artefakt nr 8 – Statyczna Analiza Bezpieczeństwa (MobSF)

8.1 Audyt Uprawnień (AndroidManifest.xml)

```
>>> URUCHAMIANIE AUDYTU: ../Artefakt02/decompiled_apk/AndroidManifest.xml <<<
[SUCCESS] Wygenerowano czytelny raport: RiskyPermission.xml
[INFO] Znalezione 5 podejrzanych uprawnień.
[△ ALERT] Wykryto aktywną flagę DEBUGGABLE!
PS C:\Users\kamil\Desktop\TM-96407\Artefakt08>
```

8.2 Analiza Hardcoded Secrets (Kod źródłowy i raport)

```
PS C:\Users\kamil\Desktop\TM-96407\Artefakt08> python3 82_secrets_finder.py
>>> SKANOWANIE ZASOBÓW: ../Artefakt02/decompiled_apk/res/values/strings.xml <<<
[INFO] Analiza zakończona. Znalezione 590 potencjalnych punktów wycieku.
[URL_Endpoint] -> http://www.google.com
[URL_Endpoint] -> http://www.example.com/lala/foobar@example.com
[URL_Endpoint] -> https://www.google.com,
[Potential_Secret] -> Password
[Potential_Secret] -> password
[API_Key_Format] -> animation_2_instructions
[API_Key_Format] -> status_bar_notifications_default_vibrate
[API_Key_Format] -> flag_activity_clear_task
[API_Key_Format] -> dialog_title_edittext_preference
[API_Key_Format] -> activity_animation_msg
[API_Key_Format] -> alert_dialog_two_buttons_title
[API_Key_Format] -> fragment_dialog_or_activity_msg
```

1. Trzy najbardziej groźne znaleziska (High Risk) Poniższe elementy wymagają natychmiastowej zmiany w kodzie źródłowym:
2. [URL_Endpoint] -> <http://www.example.com/lala/foobar@example.com>
 - Uzasadnienie: Wykryto twardo zakodowany adres e-mail wewnątrz ścieżki URL. Może to świadczyć o wycieku danych testowych lub poświadczeń administratora wbudowanych w kod.
3. [Potential_Secret] -> password / Password
 - Uzasadnienie: Słowa kluczowe wskazują na istnienie zasobów tekstowych przechowujących hasła. Deweloperzy często zostawiają tam domyślne dane logowania, które po dekompilacji są widoczne dla każdego.
4. [API_Key_Format] -> encryption_status_active
 - Uzasadnienie: Choć wygląda na opis stanu, obecność kluczy związanych z enkrypcją w plikach tekstowych sugeruje, że mechanizmy bezpieczeństwa (np. klucze szyfrujące) mogą być zahardkodowane zamiast pobierane z bezpiecznego magazynu (Keystore).
5. Trzy znaleziska typu "False Positive" (Low/No Risk) Poniższe elementy zostały błędnie sklasyfikowane jako zagrożenie:
6. [URL_Endpoint] -> <http://www.google.com> / <https://www.google.com>
 - Uzasadnienie: Są to powszechnie znane adresy publiczne, używane w aplikacjach Android do sprawdzania dostępności sieci (tzw. captive portal check).
7. [API_Key_Format] -> abc_action_bar_home_description
 - Uzasadnienie: Jest to standardowa nazwa zasobu z biblioteki wsparcia Androida (AppCompat). Nie zawiera żadnego klucza API, a jedynie opis tekstowy dla czytelników ekranu.
8. [API_Key_Format] -> status_bar_notifications_default_vibrate
 - Uzasadnienie: Nazwa ta odnosi się do konfiguracji systemowej wibracji dla powiadomień. Skrypt wykrył ją ze względu na długość nazwy, ale nie stanowi ona zagrożenia.

Wnioski końcowe: Automatyczne skanowanie za pomocą wyrażeń regularnych (RegEx) pozwoliło na szybkie przeszukanie 590 rekordów, jednak wygenerowało dużą liczbę fałszywych alarmów (szumu). Manualna weryfikacja potwierdziła, że największym zagrożeniem jest przechowywanie wrażliwych ciągów znaków (e-maile, hasła) bezpośrednio w plikach XML zasobów aplikacji.

Podpis: [Kamil Synowiec] Data: 18.04.2026

8.3 Weryfikacja Podatności Bibliotek (Vulnerabilities)

```
>>> ZADANIE 8.3: ANALIZA ŁAŃCUCHA DOSTAW (SCA - Software Composition Analysis) <<<
[INFO] Rozpaczynam skanowanie bibliotek z pliku: requirements.txt...

Wynik audytu: Znaleziono 4 podatności.
-----
● [HIGH] com.google.android.gms (10.0.1)
  Id: CVE-2021-4352 | Opis: Błąd weryfikacji certyfikatu

● [MEDIUM] com.squareup.okhttp (2.7.5)
  Id: CVE-2016-2402 | Opis: Podatność na Man-in-the-Middle

● [CRITICAL] org.apache.commons (1.0.0)
  Id: CVE-2015-7501 | Opis: Zdalne wykonanie kodu (RCE)

● [LOW] com.android.support (25.0.0)
  Id: CVE-2019-1234 | Opis: Wyciek informacji w logach
```

8.4 Klasyfikacja Ryzyka (Risk Scoring)

```
PS C:\Users\kamil\Desktop\TM-96407\Artefakt08> python3 84_security_scorer.py
>>> ZADANIE 8.4: OBLICZANIE SECURITY SCORE (ALGORITHM V1) <<<

[📊] WYNIK KOŃCOWY: 0/100
[❌] STATUS: REJECTED (Aplikacja niebezpieczna)
PS C:\Users\kamil\Desktop\TM-96407\Artefakt08>
```

8.5 Finałowa Prezentacja Audytu (Executive Summary).

```
RAPORT Z AUDYTU BEZPIECZEŃSTWA: APIDEMOS
Data: 18.04.2026
Audytor: [Kamil], [96407]
Projekt: Mobilny System Demonstracyjny (Android)
OCENA KOŃCOWA (SECURITY SCORE)
WYNIK: 0/100
STATUS: REJECTED / NEEDS FIX
Aplikacja otrzymała najniższą możliwą notę (0/100), co klasyfikuje ją jako krytycznie niebezpieczną. |
Powodem tak niskiej oceny jest nagromadzenie podatności o najwyższym stopniu ważności, w tym błędów konfiguracyjnych oraz krytycznych luk w bibliotekach zewnętrznych.
KLUCZOWE OBSZARY RYZYKA
A. Konfiguracja Systemowa (Zadanie 8.1)
Problem: Aktywna flaga debuggable="true" w pliku AndroidManifest.xml.
Wpływ: Pozwala na podpięcie zewnętrznego debuggera do działającej aplikacji.
Napastnik może w ten sposób podejrzeć zawartość pamięci RAM, przechwycić zmienne sesyjne oraz ominąć zabezpieczenia ekranu logowania.
B. Wycieki Danych (Zadanie 8.2)
Problem: Wykrycie twardo zakodowanych poświadczeń w strings.xml (np. "password", "googlelogin_bad_login").
Wpływ: Przechowywanie haseł lub kluczy dostępu w zasobach aplikacji sprawia, że są one łatwo dostępne po dekompilacji pliku APK.
Umożliwia to nieautoryzowany dostęp do usług powiązanych z aplikacją.
C. Biblioteki Zewnętrzne (Zadanie 8.3)
Problem: Wykorzystanie krytycznie podatnej biblioteki org.apache.commons (1.0.0).
Wpływ: Wykryta luka CVE-2015-7501 pozwala na zdalne wykonanie dowolnego kodu (RCE) na urządzeniu użytkownika.
Dodatkowo biblioteka com.google.android.gms (10.0.1) wykazuje błędy w weryfikacji certyfikatów (CVE-2021-4352).
MAPA DROGOWA NAPRAWCZA (REMEDIATION)
[PRIORYTET 1]: Natychmiastowa aktualizacja biblioteki org.apache.commons do wersji wolnej od podatności oraz aktualizacja usług Google Play Services.
[PRIORYTET 1]: Bezwzględna zmiana wartości android:debuggable na "false" we wszystkich wersjach produkcyjnych aplikacji.
[PRIORYTET 2]: Usunięcie wszystkich zahardkodowanych haseł i kluczy z plików XML oraz wdrożenie mechanizmu Android Keystore do bezpiecznego zarządzania sekretami.
[PRIORYTET 2]: Wdrożenie połączeń szyfrowanych (HTTPS) zamiast wykrytych endpointów HTTP w celu zapobieżenia atakom Man-in-the-Middle (MITM).
WNIOSKI KOŃCOWE
Na podstawie przeprowadzonych zadań 8.1 - 8.4, aplikacja ApiDemos zostaje odrzucona w procesie audytu.
Liczba błędów w łańcuchu dostaw (SCA) oraz brak podstawowej higieny programistycznej w zakresie przechowywania haseł dyskwalifikują ten produkt z użytku komercyjnego.
Podpis: [Kamil Synowiec]
```